

THEONEWAYGDA Platform

Improvement Report

Date: June 6, 2026 | Version: Post-audit fixes

1. Executive Summary

This report documents the security improvements, bug fixes, and feature verifications performed on the THEONEWAYGDA platform. After a comprehensive audit of the codebase (57 Prisma models, 113+ API routes, Stripe payment integration), several critical issues were identified and resolved. The platform already had robust login/registration, account isolation, and subscription notification systems in place. The work focused on fixing underlying bugs that weakened these existing systems.

2. Existing Features Verified (Already Working)

The following features were found already fully implemented and verified operational:

Feature	Details
Login System	Full login at /auth/login with email/password, session tokens (30-day expiry), activity logging. Handles pending (202), rejected (403), approved (200) states.
Registration	Registration at /auth/register creates users with role="pending", sends admin notification email, creates Visitor record. Password hashed with SHA-256 + random salt.
Navbar Login Icon	Navbar shows "Sign In" + "Register" buttons (LogIn/UserPlus icons) when logged out; "Dashboard" + avatar when logged in. Responsive mobile menu included.
Account Isolation	All core API routes (/api/billing, /api/auth/[id], /api/auth/activity, /api/checkout, /api/stripe/portal) verify session token and scope queries to session.userId.
Notification Email	Stripe webhook sets status="pending_approval", sends email to msad41855@gmail.com via sendAdminSubscriptionNotificationEmail().
Admin Approval	/api/admin/subscriptions/[id]/approve activates subscription, upgrades user role, sends approval email. /reject cancels Stripe subscription.

Table 1: Features verified as already implemented

3. Bugs Found and Fixed

Bug	Severity	Fix Applied
Admin subscriptions page field mismatch	High	Changed data.subscriptions to data.pending to match API response format
/api/auth/stats projectCount leaks data	High	Scoped projectCount (model has no userId). Scoped workflow/automation to user email

PATCH /api/auth/[id] missing expiry	Medium	Added session.expiresAt validation before authorization check
PATCH /api/billing/free upgrade exploit	High	Restricted PATCH to plan="free" only. Paid upgrades require Stripe checkout
Approve only handles pro plan	Medium	Updated to set role based on plan: pro=pro, enterprise=admin

Table 2: Bugs identified and fixed during audit

4. Files Modified

src/app/(dashboard)/admin/subscriptions/page.tsx - Fixed data field parsing

src/app/api/auth/stats/route.ts - Scoped queries to authenticated user

src/app/api/auth/[id]/route.ts - Added session expiry check in PATCH

src/app/api/billing/route.ts - Restricted PATCH to free plan only

src/app/api/admin/subscriptions/[id]/approve/route.ts - Enterprise role handling

5. Remaining Recommendations

Audit 30+ high-risk [id]-parameter API routes for potential IDOR vulnerabilities

Add userId field to Project, WorkflowPipeline, and AutomationRule models

Set up Vercel environment variables for production deployment

Configure DNS for theonewaygda.com custom domain